Internship Assignment Report

Mobile Application Penetration Testing on DIVA

Name: Azeem

Course: Cybersecurity Internship

Application Tested: DIVA (Damn Insecure Vulnerable App)

Tools Used:

* ADB
* MobSF
* APKTool
* Jarsigner
* Zipalign
* Genymotion Emulator
* Kali Linux

1. Objective

The objective of this assignment is to perform **mobile application penetration testing** on an intentionally vulnerable Android application (DIVA) to understand common security vulnerabilities present in mobile applications.

2. Environment Setup

The testing environment was prepared using:

* Kali Linux (Virtual Machine)

* Genymotion Android Emulator

* Android Debug Bridge (ADB)

The emulator device was connected using ADB to perform testing operations.

Screenshot

ADB connection and ADB information

```
┌──(kali㉿kali)-[~]
└─$ adb connect 192.168.34.104
* daemon not running; starting now at tcp:5037
* daemon started successfully
connected to 192.168.34.104:5555

┌──(kali㉿kali)-[~]
└─$ adb devices
List of devices attached
192.168.34.104:5555     device


┌──(kali㉿kali)-[~]
└─$ adb shell getprop ro.build.version.release
11

┌──(kali㉿kali)-[~]
└─$ adb shell getprop ro.product.model
Phone

┌──(kali㉿kali)-[~]
└─$ adb shell getprop ro.product.manufacturer
Genymobile
```

3. Root Access Verification

The Android emulator used in this assessment had root access enabled.

The following command was used to verify root privileges:

* adb root

* adb shell

This confirms full system level access which can be exploited by malicious applications.

Screenshots

adb root

```
┌──(kali㉿kali)-[~]
└─$ adb root
adbd is already running as root
```

adb shell

```
┌──(kali㉿kali)-[~]
└─$ adb shell
genymotion:/ #
```

Whoami

```
┌──(kali㉿kali)-[~]
└─$ adb shell
genymotion:/ # whoami
root
genymotion:/ #
```

4. Application Installation

The DIVA application APK was installed on the emulator using ADB command.

adb install DivaApplication.apk

This confirms successful deployment of the application in the test environment.

Screenshot

APK Installation Success

```
┌──(kali㉿kali)-[~/Downloads/diva-apk-file]
└─$ adb install DivaApplication.apk
Performing Streamed Install
Success
```

5. Data Extraction Vulnerability

Sensitive data was extracted from the application storage directory.

The shared preferences file contained hardcoded credentials such as:

* Username

* Password

This demonstrates **insecure data storage vulnerability

Screenshot

shared_prefs password extraction

```
GNU nano 8.6
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
    <string name="password">12345</string>
    <string name="user">azeem</string>
</map>
```

6. Static Analysis using MobSF

Static analysis was performed using Mobile Security Framework (MobSF).

The following issues were identified:

* Debug mode enabled

* Application backup allowed

* Exported activities without protection

* Dangerous permissions used

This indicates weak security configuration in the application.

Screenshot

mobSF security score

MANIFEST ANALYSIS

HIGH	WARNING	INFO	SUPPRESSED
2	4	0	0

Search:

NO	ISSUE	SEVERITY	DESCRIPTION	OPTIONS
1	App can be installed on a vulnerable unpatched Android version 4.0.3-4.0.4, [minSdk=15]	high	This application can be installed on an older version of android that has multiple unfixed vulnerabilities. These devices won't receive reasonable security updates from Google. Support an Android version => 10, API 29 to receive reasonable security updates.	
2	Debug Enabled For App [android:debuggable=true]	high	Debugging was enabled on the app which makes it easier for reverse engineers to hook a debugger to it. This allows dumping a stack trace and accessing debugging helper classes.	
3	Application Data can be Backed up [android:allowBackup=true]	warning	This flag allows anyone to backup your application data via adb. It allows users who have enabled USB debugging to copy application data off of the device.	
4	Activity (jakhar.aseem.diva.APICredsActivity) is not Protected. An intent-filter exists.	warning	An Activity is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device. The presence of intent-filter indicates that the Activity is explicitly exported.	
5	Activity (jakhar.aseem.diva.APICreds2Activity) is not Protected. An intent-filter exists.	warning	An Activity is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device. The presence of intent-filter indicates that the Activity is explicitly exported.	
6	Content Provider (jakhar.aseem.diva.NotesProvider) is not Protected. [android:exported=true]	warning	A Content Provider is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device.	

Permissions

APPLICATION PERMISSIONS

Search:

PERMISSION	STATUS	INFO	DESCRIPTION	CODE MAPPINGS
android.permission.INTERNET	normal	full Internet access	Allows an application to create network sockets.	
android.permission.READ_EXTERNAL_STORAGE	dangerous	read external storage contents	Allows an application to read from external storage.	
android.permission.WRITE_EXTERNAL_STORAGE	dangerous	read/modify/delete external storage contents	Allows an application to write to external storage.	

Manifest analysis

MANIFEST ANALYSIS

HIGH	WARNING	INFO	SUPPRESSED
2	4	0	0

Search:

NO	ISSUE	SEVERITY	DESCRIPTION	OPTIONS
1	App can be installed on a vulnerable unpatched Android version 4.0.3-4.0.4, [minSdk=15]	high	This application can be installed on an older version of android that has multiple unfixed vulnerabilities. These devices won't receive reasonable security updates from Google. Support an Android version => 10, API 29 to receive reasonable security updates.	
2	Debug Enabled For App [android:debuggable=true]	high	Debugging was enabled on the app which makes it easier for reverse engineers to hook a debugger to it. This allows dumping a stack trace and accessing debugging helper classes.	
3	Application Data can be Backed up [android:allowBackup=true]	warning	This flag allows anyone to backup your application data via adb. It allows users who have enabled USB debugging to copy application data off of the device.	
4	Activity (jakhar.aseem.diva.APICredsActivity) is not Protected. An intent-filter exists.	warning	An Activity is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device. The presence of intent-filter indicates that the Activity is explicitly exported.	
5	Activity (jakhar.aseem.diva.APICreds2Activity) is not Protected. An intent-filter exists.	warning	An Activity is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device. The presence of intent-filter indicates that the Activity is explicitly exported.	
6	Content Provider (jakhar.aseem.diva.NotesProvider) is not Protected. [android:exported=true]	warning	A Content Provider is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device.	

7. Reverse Engineering using APKTool

The Android application package (APK) was reverse engineered using **APKTool** to analyze its internal structure, resources, and security configurations.

The following command was used to decompile the application:

apktool d DivaApplication.apk

During the analysis, the **AndroidManifest.xml** file was examined to identify potential security misconfigurations.

It was observed that the application had the attribute:

android:debuggable="true"

This configuration indicates that the application can be debugged, which may allow attackers to perform runtime analysis, memory inspection, and reverse engineering attacks.

Such configurations are considered insecure in production environments.

Screenshot

APK Decompile

```
┌──(root㉿kali)-[/home/kali/Downloads/diva-apk-file]
└─# apktool d  DivaApplication.apk
I: Using Apktool 2.7.0-dirty on DivaApplication.apk
I: Loading resource table ...
I: Decoding AndroidManifest.xml with resources ...
I: Loading resource table from file: /root/.local/share/apktool/framework/1.apk
I: Regular manifest package ...
I: Decoding file-resources ...
I: Decoding values */* XMLs ...
I: Baksmaling classes.dex ...
I: Copying assets and libs ...
I: Copying unknown files ...
I: Copying original files ...
```

Manifest file (debuggable)

```
<?xml version="1.0" encoding="utf-8" standalone="no" ?><manifest xmlns:android="http://schemas.android.com/apk/res/android" package="jakhar.aseem.diva" platformBuildVersionCode="23" platformBuildVersionName="6.0-2166767" >
    <uses-permission android:name="android.permission.WRITE_EXTERNAL_STORAGE"/>
    <uses-permission android:name="android.permission.READ_EXTERNAL_STORAGE"/>
    <uses-permission android:name="android.permission.INTERNET"/>
    <application android:allowBackup="true" android:debuggable="true" android:icon="@mipmap/ic_launcher" android:label="@string/app_name" android:supportsRtl="true" android:theme="@style/AppTheme">
        <activity android:label="@string/app_name" android:name="jakhar.aseem.diva.MainActivity" android:theme="@style/AppTheme.NoActionBar">
            <intent-filter>
                <action android:name="android.intent.action.MAIN"/>
                <category android:name="android.intent.category.LAUNCHER"/>
            </intent-filter>
        </activity>
        <activity android:label="@string/d1" android:name="jakhar.aseem.diva.LogActivity"/>
        <activity android:label="@string/d2" android:name="jakhar.aseem.diva.HardcodeActivity"/>
        <activity android:label="@string/d3" android:name="jakhar.aseem.diva.InsecureDataStorage1Activity"/>
        <activity android:label="@string/d4" android:name="jakhar.aseem.diva.InsecureDataStorage2Activity"/>
        <activity android:label="@string/d5" android:name="jakhar.aseem.diva.InsecureDataStorage3Activity"/>
        <activity android:label="@string/d6" android:name="jakhar.aseem.diva.InsecureDataStorage4Activity"/>
        <activity android:label="@string/d7" android:name="jakhar.aseem.diva.SQLInjectionActivity"/>
        <activity android:label="@string/d8" android:name="jakhar.aseem.diva.InputValidation2URISchemeActivity"/>
        <activity android:label="@string/d9" android:name="jakhar.aseem.diva.AccessControl1Activity"/>
        <activity android:label="@string/apic_label" android:name="jakhar.aseem.diva.APICredsActivity">
            <intent-filter>
                <action android:name="jakhar.aseem.diva.action.VIEW_CREDS"/>
                <category android:name="android.intent.category.DEFAULT"/>
            </intent-filter>
        </activity>
        <activity android:label="@string/d10" android:name="jakhar.aseem.diva.AccessControl2Activity"/>
        <activity android:label="@string/apic2_label" android:name="jakhar.aseem.diva.APICreds2Activity">
            <intent-filter>
                <action android:name="jakhar.aseem.diva.action.VIEW_CREDS2"/>
                <category android:name="android.intent.category.DEFAULT"/>
            </intent-filter>
        </activity>
        <provider android:authorities="jakhar.aseem.diva.provider.notesprovider" android:enabled="true" android:exported="true" android:name="jakhar.aseem.diva.NotesProvider"/>
        <activity android:label="@string/d11" android:name="jakhar.aseem.diva.AccessControl3Activity"/>
        <activity android:label="@string/d12" android:name="jakhar.aseem.diva.Hardcode2Activity"/>
        <activity android:label="@string/pnotes" android:name="jakhar.aseem.diva.AccessControl3NotesActivity"/>
        <activity android:label="@string/d13" android:name="jakhar.aseem.diva.InputValidation3Activity"/>
    </application>
</manifest>
```

8. APK Recompilation

After modification, the application was rebuilt using:

apktool b DivaApplication

This generated a modified APK file.

Screenshot

APK Build Success

```
┌──(root㉿kali)-[/home/kali/Downloads/diva-apk-file]
└─# apktool b DivaApplication
I: Using Apktool 2.9.3
I: Checking whether sources has changed ...
I: Smaling smali folder into classes.dex ...
I: Checking whether resources has changed ...
I: Building resources ...
I: Copying libs ... (/lib)
I: Building apk file ...
I: Copying unknown files/dir ...
I: Built apk into: DivaApplication/dist/DivaApplication.apk
```

9.APK Signing

A keystore was generated and the APK was digitally signed.

keytool -genkey

jarsigner

Signing ensures APK integrity and allows installation on Android devices.

APK signing ensures integrity and authenticity of application.

Unsigned APKs cannot be installed on Android devices.

Screenshot

Keystore Generation

```
Is CN=azeem, OU=Unknown, O=Unknown, L=Unknown, ST=Unknown, C=IN correct?
  [no]:  yes

Generating 2,048 bit RSA key pair and self-signed certificate (SHA384withRSA) with a validity of 10,000 days
        for: CN=azeem, OU=Unknown, O=Unknown, L=Unknown, ST=Unknown, C=IN
[Storing diva.keystore]
```

APK Signed

```
>>> Signer
    X.509, CN=azeem, OU=Unknown, O=Unknown, L=Unknown, ST=Unknown, C=IN
    Signature algorithm: SHA384withRSA, 2048-bit key
    [trusted certificate]

jar signed.

Warning:
The signer's certificate is self-signed.
The SHA1 algorithm specified for the -digestalg option is considered a security risk and is disabled.
The SHA1withRSA algorithm specified for the -sigalg option is considered a security risk and is disabled.
```

10. APK Optimization using Zipalign

The APK was optimized using zipalign for proper memory alignment.

zipalign -v 4 DivaApplication/dist/DivaApplication.apk DivaFinal.apk

Screenshot

Zipalign Verification

```
┌──(root㉿kali)-[/home/kali/Downloads/diva-apk-file]
└─# zipalign -v 4 DivaApplication/dist/DivaApplication.apk DivaFinal.apk
Verifying alignment of DivaFinal.apk (4)...
      50 META-INF/MANIFEST.MF (OK - compressed)
   11872 META-INF/DIVA.SF (OK - compressed)
   23785 META-INF/DIVA.RSA (OK - compressed)
   25004 lib/armeabi-v7a/libdivajni.so (OK - compressed)
   30543 lib/mips/libdivajni.so (OK - compressed)
   32085 lib/x86/libdivajni.so (OK - compressed)
   33618 lib/armeabi/libdivajni.so (OK - compressed)
   39160 lib/mips64/libdivajni.so (OK - compressed)
   40791 lib/arm64-v8a/libdivajni.so (OK - compressed)
   42178 lib/x86_64/libdivajni.so (OK - compressed)
   43580 classes.dex (OK - compressed)
  963940 resources.arsc (OK)
 1198101 AndroidManifest.xml (OK - compressed)
```

11. Installation of Modified APK

The modified APK was successfully installed on the emulator.

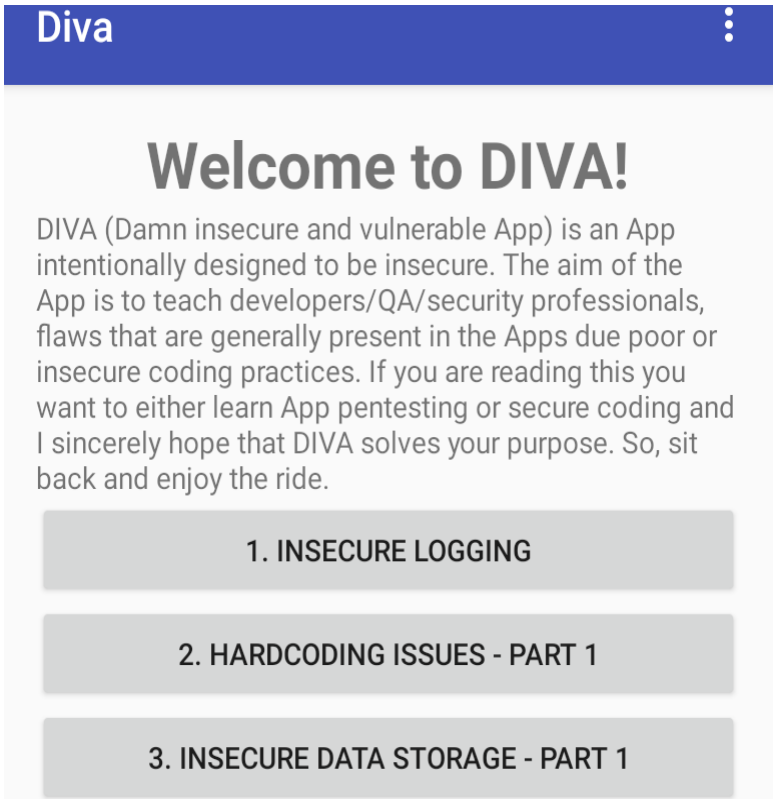
adb install DivaFinal.apk

Screenshot

Final APK Installed

```
┌──(root㉿kali)-[/home/kali/Downloads/diva-apk-file]
└─# adb install  DivaFinal.apk
Performing Streamed Install
Success
```

Application Running



12. Conclusion

This assignment provided practical exposure to:

* Android application penetration testing
* Static analysis
* Reverse engineering
* APK modification
* Digital signing and deployment

The DIVA application demonstrates multiple real-world Android vulnerabilities including insecure data storage, debug enabled configuration, exported components and unsafe permissions.

This assessment provided hands-on experience in mobile penetration testing, reverse engineering and secure coding analysis.

12. Learning Outcome

Through this assignment, the following skills were developed:

* Mobile security assessment
* Android reverse engineering
* Vulnerability identification
* Secure application testing workflow